Segurança de Dados

Adaptado dos
materiais da professora Raqueline Penteado

Sumário

- Introdução
- Segurança
  - Proteção do Banco de Dados
  - Proteção de Regiões
    - Controle de Acesso Discricionário
    - Controle de Acesso Obrigatório
  - Proteção de Banco de Dados Estatísticos
  - Proteção de Dados com Criptografia

Introdução

- **Segurança de Dados**
  - **Integridade**
    - Proteger os dados contra **usuários autorizados**.
  - **Segurança**
    - Proteger os dados contra usuários **não autorizados**.

Introdução

- **Segurança de Dados**
  - É importante **garantir** que os usuários tenham **permissão** para **fazer somente aquilo** que estão **autorizados**.
    - Consiste na **definição de restrições** apropriadas, as quais **não devem ser violadas**.
    - Necessidade de um **subsistema de Segurança** e de **Autorização**.

Introdução

- **Objetivo principal no estudo de segurança**
  - Aprender sobre técnicas utilizadas para proteger o Banco de Dados (BD) contra usuários que não são autorizados a acessar uma parte ou o banco como um todo.

- O **Administrador do Banco de Dados** é o profissional principal para o gerenciamento de um **Sistema Gerenciador de Banco de Dados** (SGBD).

Introdução

- **Responsabilidades do Administrador**
  - Criação de contas
  - Concessão de privilégios
  - Revogação de privilégios
  - Atribuição de nível de segurança

Proteção do Banco de Dados

- **Objetivo**
  - Qualquer SGBD deve oferecer **mecanismos de segurança** que **impeçam o acesso** não **autorizado de usuários** ao sistema.

- **Principais problemas**
  - Obtenção de informações não permitidas.
  - Realização de alterações maliciosas.

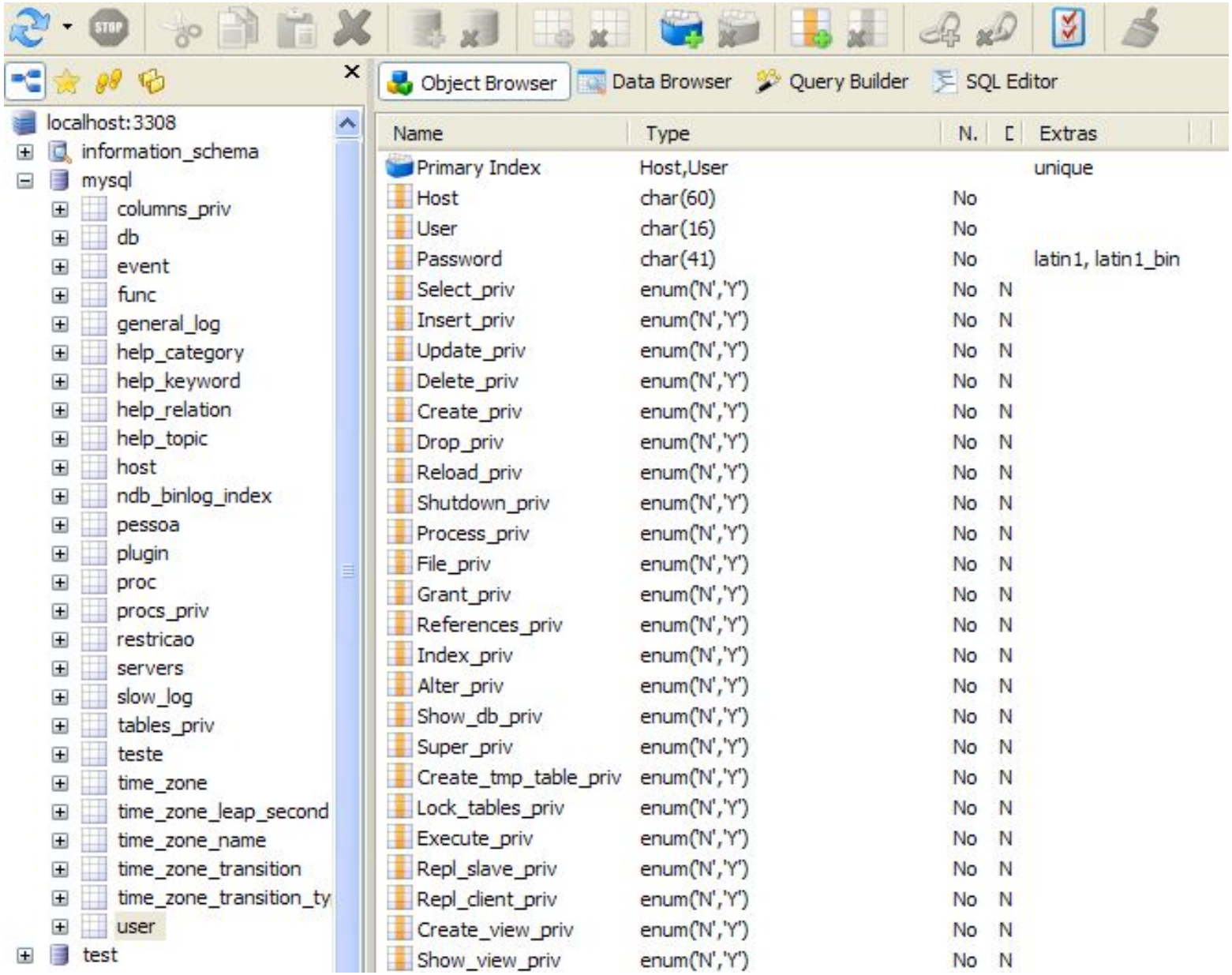
- **Solução**
  - Garantir o acesso **restrito** ao BD
    - **Solução inicial:** controle de acesso.

Exemplo MySQL

- **Uso de cinco tabelas para o controle de acesso no MySQL**
  - USER, DB, HOST, TABLES_PRIV E COLUMNS_PRIV

- **USER**
  - Usada para determinar quando **permitir** ou **aceitar** conexões.
  - Para conexões permitidas, **qualquer privilégio** concedido indica um **privilégio global**, que se aplica a todos os BDs gerenciados pelo servidor.

Exemplo MySQL



Exemplo MySQL

- **Para requisições administrativas**
  - Confere-se somente a entrada da tabela USER.

- **Para requisições relacionadas ao DB**
  - Confere-se os privilégios globais (**Tabela USER**)
    - Se a entrada permitir a operação requisitada, o acesso é concedido. Senão, as tabelas **DB** e **HOST** são conferidas.
    - Se a operação requisitada for permitida, o acesso é concedido. Senão, as tabelas **TABLES_PRIV** e **COLUMNS_PRIV** são conferidas.

Proteção Parcial do Banco de Dados

- **Objetivo**
  - Qualquer SGBD deve oferecer suporte a técnicas que garantam que **certos usuários** ou **grupos de usuários** somente acessem determinadas **regiões** do BD.

- **Principais problemas**
  - Obtenção de informações confidenciais.
  - Realização de alterações indevidas em informações confidenciais.

Proteção Parcial do Banco de Dados

- **Solução**
  - Garantir acesso **parcial** aos dados do BD
  - **Solução oferecida**
    - Subsistema de Autorização e Segurança.

Proteção Parcial do Banco de Dados

- **Tipos de Mecanismos de Segurança**
  - Mecanismos de Segurança Discretos
    - Garantem **privilégios** aos usuários, tal como **acesso** a **arquivos de dados**, **registros** ou **campos específicos** em um **determinado modo**, seja **leitura**, **escrita** ou **alteração**.
  - Mecanismos de Segurança Obrigatórios
    - Classificam os **dados** e os **usuários** em várias **classes**, ou **níveis**, de **segurança**.
    - Implementam diferentes **políticas de segurança** dentro de uma mesma organização.

Proteção Parcial do Banco de Dados

- **Mecanismos de Segurança Discretos**
  - **Método típico:** conceder e revogar privilégios.
  - **Dois níveis**
    - Nível de Conta
      - Cada **conta do usuário** possui **privilégios específicos**, independentemente das relações do BD.
      - **MySQL:** tabelas *db* e *host*.
    - Nível de Tabela
      - Cada usuário pode aplicar determinados **tipos de comando** à relações individuais, ou até mesmo a **colunas específicas** das relações.
      - **MySQL:** tabelas *tables_priv* e *columns_priv*.

Exemplo MySQL

- **DB e HOST**
  - São usadas juntas. O DB indica quais usuários podem acessar **determinados bancos**, hospedados em **determinadas máquinas**.

- **TABLES_PRIV e COLUMNS_PRIV**
  - São mecanismos de controle mais “leves”.
  - Eles são aplicados a nível de **tabelas** e **colunas**, em vez de de **BDs**.

Proteção Parcial do Banco de Dados

- **Mecanismos de Segurança Discretos**
  - Nível de Conta - Possíveis Permissões
    - SELECT
    - CREATE
    - INSERT
    - UPDATE
    - DELETE
    - INDEX
    - ALTER
    - GRANT
    - DROP

Proteção Parcial do Banco de Dados

- **Mecanismos de Segurança Discretos**
  - Nível de Tabela - Possíveis Permissões
    - SELECT
    - INSERT
    - UPDATE
    - DELETE
    - CREATE
    - DROP
    - GRANT
    - REFERENCES

Proteção Parcial do Banco de Dados

- **Mecanismos de Segurança Discretos**
  - Nível de Coluna - Possíveis Permissões
    - SELECT
    - INSERT
    - UPDATE
    - REFERENCES

Proteção Parcial do Banco de Dados

- **Mecanismos de Segurança Discretos**
  - **Conceito de Visão**
    - Certos usuários somente podem acessar determinados dados de uma tabela.
  - **Exemplo**
    - Esquema – Funcionário(<u>código</u>, nome, depto, cargo).
    - Certos usuários podem acessar somente o **nome** e o **depto**.

Proteção Parcial do Banco de Dados

- **Exemplo**

```
CREATE VIEW nome_depto AS
SELECT nome, depto FROM funcionário;
```

- **Consulta permitida**

```
SELECT * FROM nome_depto;
```

Proteção Parcial do Banco de Dados

- **Mecanismos de Segurança Discretos**
  - Especificando autorização por meio de GRANT e REVOKE.

  - **Comando GRANT**
    - Concede **privilégios sobre uma relação** a determinados usuários.

  - **Comando REVOKE**
    - Revoga **privilégios previamente concedidos** sobre uma relação a determinados usuários.

Proteção Parcial do Banco de Dados

- **Mecanismos de Segurança Discretos**
  - Sintaxe Geral
    - **Comando GRANT**

      GRANT {privilégio | ALL}
      ON {*.* | * | esquema | relação | visão}
      TO {usuário | PUBLIC}
      [**WITH GRANT OPTION**];

    - **Comando REVOKE**

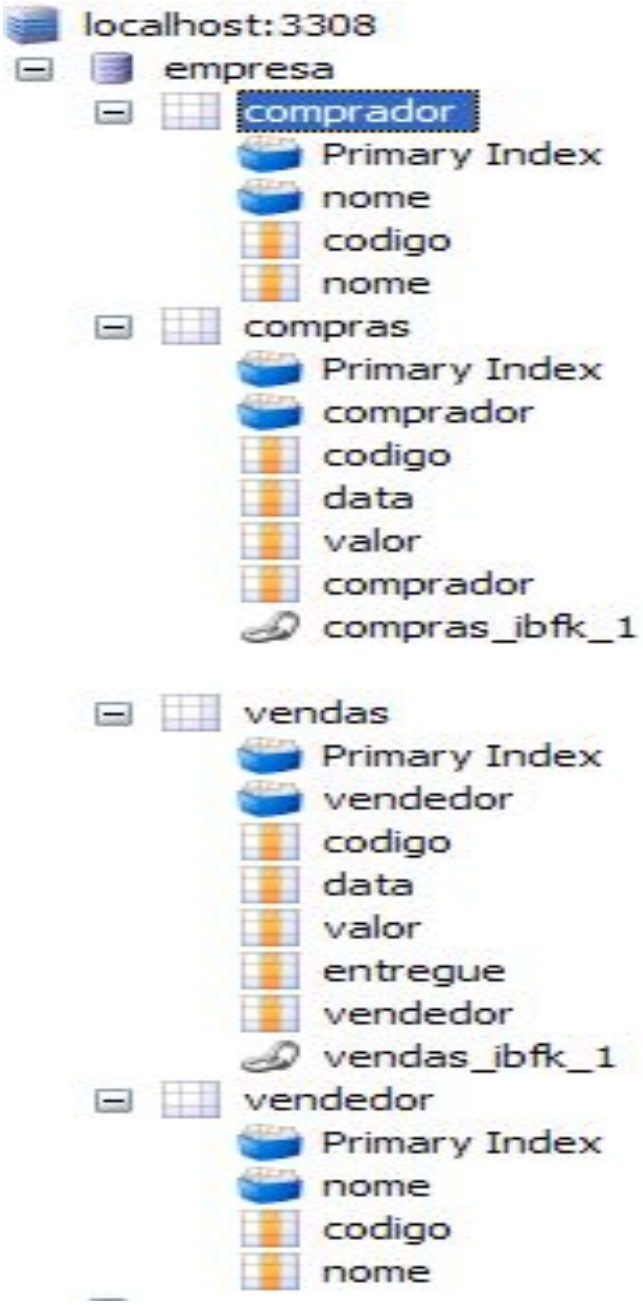
      REVOKE {privilégio | ALL}
      ON {*.* | * | esquema | relação | visão}
      FROM {usuário | PUBLIC};

Exemplo MySQL

- **Consideração dos seguintes usuários**
  - Administrador
  - GerenteCompras
  - GerenteVendas
  - UsuárioCompras
  - UsuárioVendas

Exemplo MySQL

- **Criação das seguintes tabelas**
  - Comprador
  - Compras
  - Vendas
  - Vendedor



Exemplo MySQL

- **A tabela *user* é usada no primeiro estágio do controle de acesso**
  - O usuário e o login existem?
  - Se existem, quais são as permissões GLOBAIS para ele?

- **Como criar os usuários?**
  - Alterar a tabela “user” diretamente;
  - Utilizar o comando GRANT.

Exemplo MySQL

```
GRANT  all
ON *.*
TO administrador@localhost IDENTIFIED BY 'administrador';

GRANT  all
ON *.*
TO gerentecompras@localhost IDENTIFIED BY 'gerentecompras';

GRANT  all
ON *.*
TO gerentevendas@localhost IDENTIFIED BY 'gerentevendas';

GRANT  all
ON *.*
TO usuariocompras@localhost IDENTIFIED BY 'usuariocompras';

GRANT  all
ON *.*
TO usuariovendas@localhost IDENTIFIED BY 'usuariovendas';
```

Exemplo MySQL

ao - mysql.user (Data Browser)

Database Extras Settings Help

Object Browser | Data Browser | Query Builder | SQL Editor

0 | 50 | Search

Host	User	Password	Select_priv	Insert...	Update...	Delete...	Create...	Drop...	Reload...	Shutdown...	Process...
localhost	administrador	*EFC258DA67C9F942793CDD8A2050C469256C7192	Y	Y	Y	Y	Y	Y	Y	Y	Y
localhost	gerentecompras	*5E565C3C2B000AB00D435F976AB5770DF8A2E029	Y	Y	Y	Y	Y	Y	Y	Y	Y
localhost	gerentevendas	*EE80CE8E4AB1D22F04CD72F2EE76084CAE06997B	Y	Y	Y	Y	Y	Y	Y	Y	Y
localhost	usuariocompras	*7182ADFE3EC0C445D6A5330F8063FCB2FF910189	Y	Y	Y	Y	Y	Y	Y	Y	Y
localhost	usuariovendas	*AA620C1F65B6A28B6023F863FD763F66B73B5FAA	Y	Y	Y	Y	Y	Y	Y	Y	Y

Exemplo MySQL

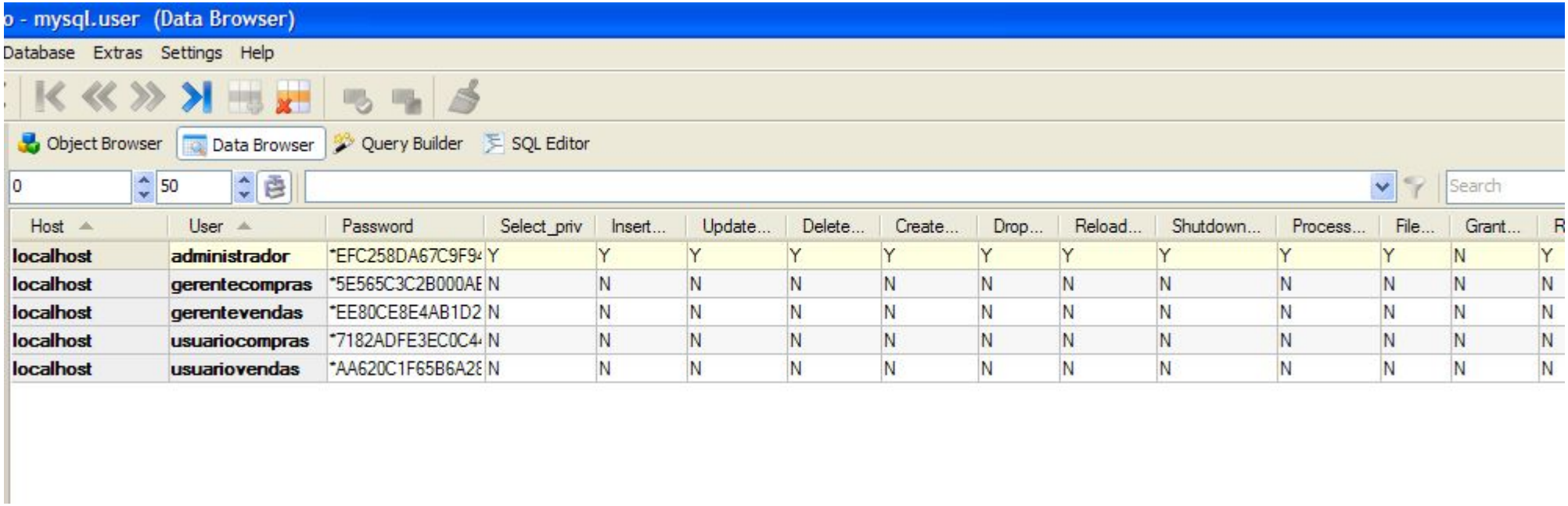
```
REVOKE all
ON *.*
FROM gerentecompras@localhost;

REVOKE all
ON *.*
FROM gerentevendas@localhost;

REVOKE all
ON *.*
FROM usuariocompras@localhost;

REVOKE all
ON *.*
FROM usuariovendas@localhost;
```

Exemplo MySQL



Host	User	Password	Select_priv	Insert...	Update...	Delete...	Create...	Drop...	Reload...	Shutdown...	Process...	File...	Grant...	R
localhost	administrador	*EFC258DA67C9F9	Y	Y	Y	Y	Y	Y	Y	Y	Y	Y	N	Y
localhost	gerentecompras	*5E565C3C2B000AE	N	N	N	N	N	N	N	N	N	N	N	N
localhost	gerentevendas	*EE80CE8E4AB1D2	N	N	N	N	N	N	N	N	N	N	N	N
localhost	usuariocompras	*7182ADFE3EC0C4	N	N	N	N	N	N	N	N	N	N	N	N
localhost	usuariovendas	*AA620C1F65B6A2	N	N	N	N	N	N	N	N	N	N	N	N

Exemplo MySQL

- **Considerar as seguintes restrições de acesso**
  - Administrador tem **total acesso** (superusuário);
  - GerenteCompras tem **total acesso** às tabelas referentes a **Compras**;
  - GerenteVendas tem **total acesso** às tabelas referentes a **Vendas**;
  - UsuárioCompras somente pode **consultar e atualizar** a **tabela Compras**;
  - UsuárioVendas pode **consultar a tabela Vendas** e **alterar valores** na coluna "**entregue**" da mesma;

Exemplo MySQL

- **GerenteCompras tem total acesso às tabelas referentes a Compras**

  GRANT all

  ON compras, comprador

  TO gerentecompras@localhost **identified by** 'gerentecompras';

- **GerenteVendas tem total acesso às tabelas referentes a Vendas**

  GRANT all

  ON vendas, vendedor

  TO gerentevendas@localhost **identified by** 'gerentevendas';

Exemplo MySQL

- **UsuárioCompras somente pode consultar e atualizar a tabela Compras**

  GRANT select, update

  ON compras

  TO usuariocompras@localhost **identified by** 'usuariocompras';

Exemplo MySQL

- **UsuárioVendas somente pode consultar a tabela Vendas e alterar valores na coluna “entregue” da tabela Vendas**

```
GRANT select
ON vendas
TO usuariovendas@localhost identified by 'usuariovendas';

GRANT update(entregue)
ON vendas
TO usuariovendas@localhost identified by 'usuariovendas';
```

Exemplo MySQL

exao - mysql.tables_priv (Data Browser)

es Database Extras Settings Help

Object Browser | Data Browser | Query Builder | SQL Editor

0 | 50

Host	Db	User	Table_name	Grantor	Timestamp	Table_priv
localhost	empresa	usuariocompras	compras	root@localhost	2008-09-09 16:41:25	Select,Update
localhost	empresa	usuariovendas	vendas	root@localhost	2008-09-09 16:45:01	Select
localhost	empresa	gerentecompras	comprador	root@localhost	2008-09-09 16:38:15	Select,Insert,Update,Delete,Create,Drop,Refer
localhost	empresa	gerentecompras	compras	root@localhost	2008-09-09 16:38:24	Select,Insert,Update,Delete,Create,Drop,Refer
localhost	empresa	gerentevendas	vendas	root@localhost	2008-09-09 16:39:45	Select,Insert,Update,Delete,Create,Drop,Refer
localhost	empresa	gerentevendas	vendedor	root@localhost	2008-09-09 16:39:50	Select,Insert,Update,Delete,Create,Drop,Refer

o - mysql.columns_priv (Data Browser)

Database Extras Settings Help

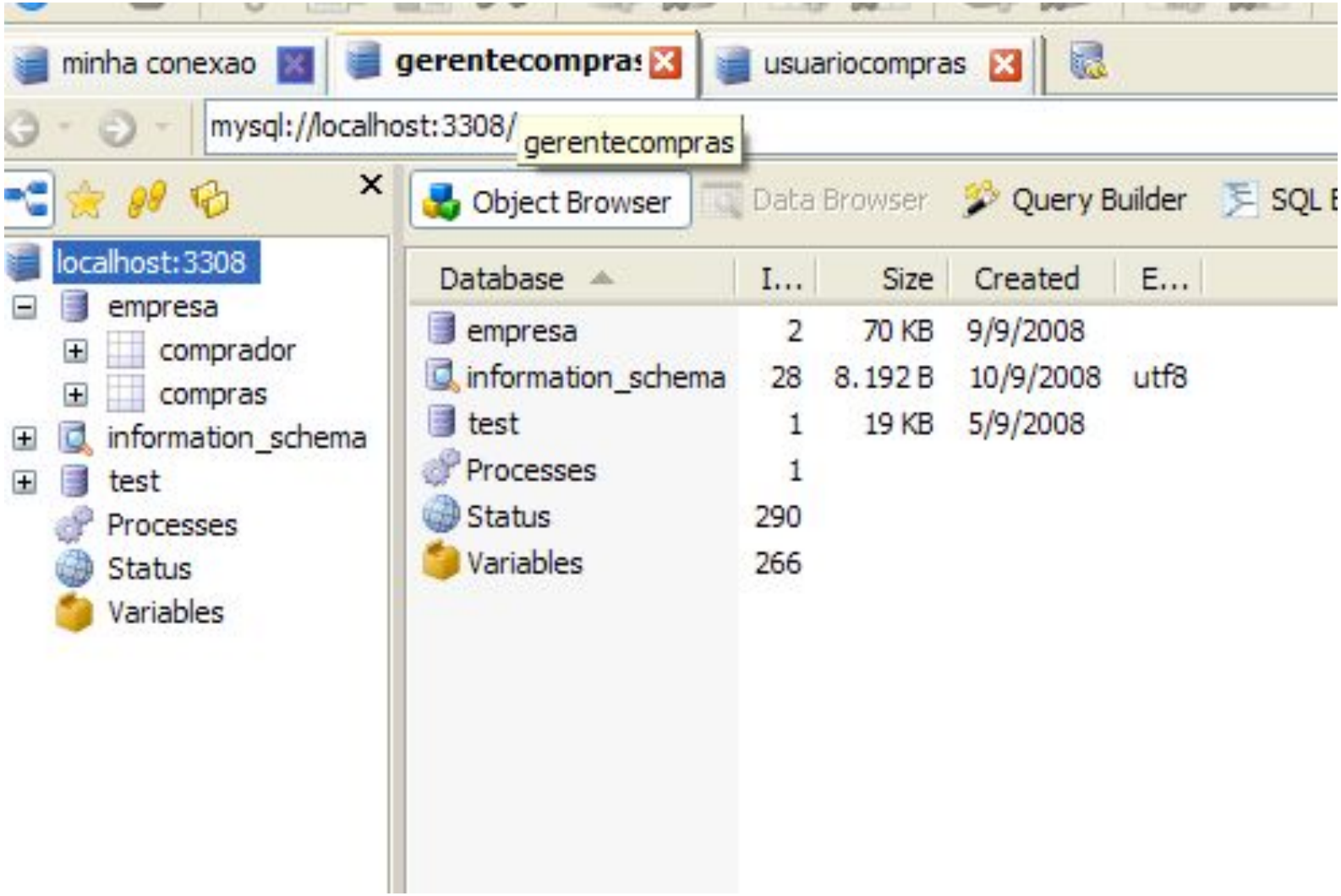
Object Browser | Data Browser | Query Builder | SQL Editor

0 | 50

Host	Db	User	Table_name	Column_...	Timestamp	Column_priv
localhost	empresa	usuariovendas	vendas	entregue	2008-09-09 16:45:01	Update

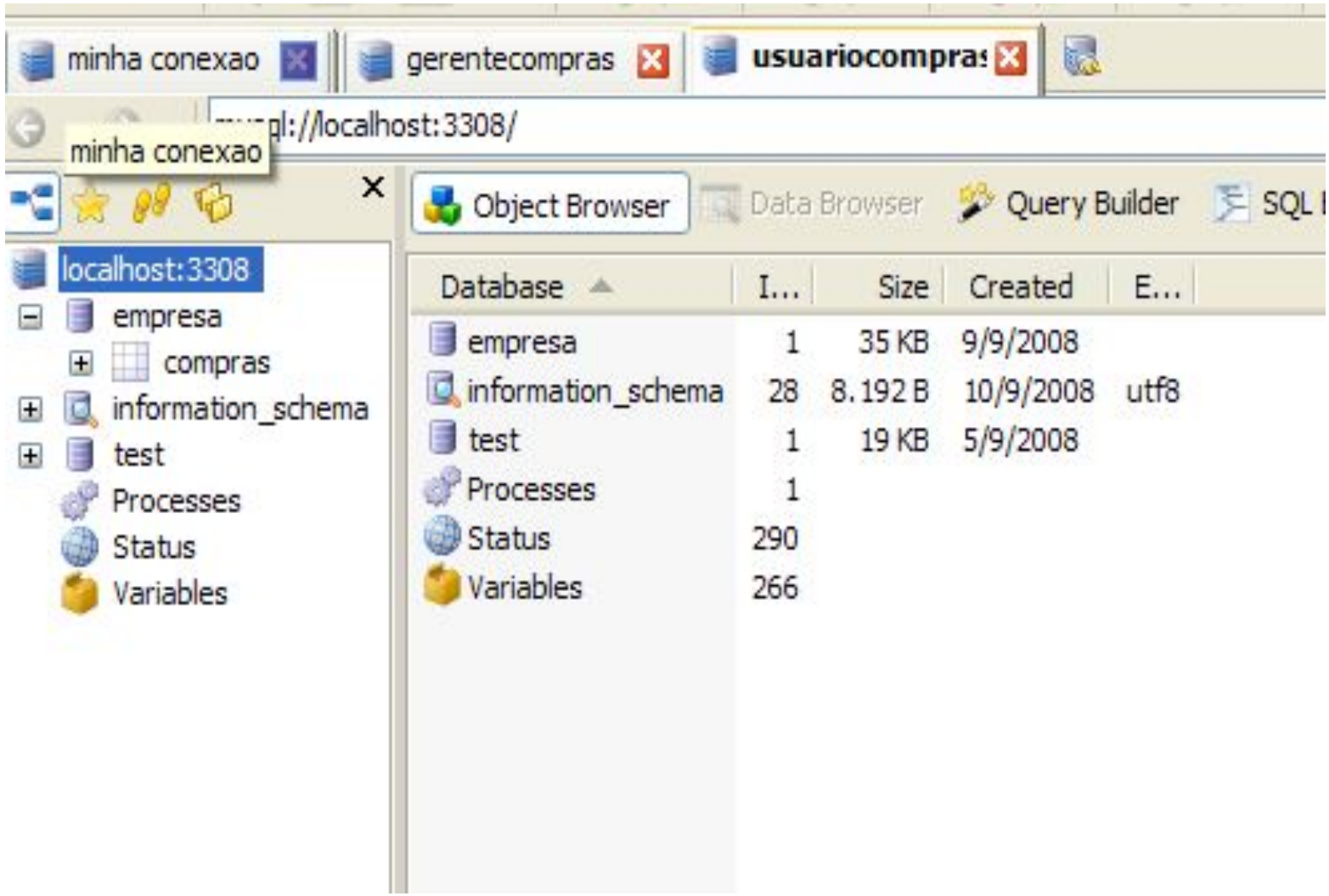
Exemplo MySQL

- **Gerente de Compras acessando o BD**



Exemplo MySQL

- **Usuário Compras acessando o BD**



Proteção Parcial do Banco de Dados

- **Mecanismos de Segurança Discretos**
  - Propagação de Privilégios
    - Proprietário de uma relação
      - **Criador** da relação;
      - Possui **todos os privilégios** sobre a relação;
      - Tem a **capacidade** de **conceder** e **revogar privilégios** de outros usuários sobre a relação.
  - Cláusula **WITH GRANT OPTION**
    - Permite que o **usuário** que **acabou de receber privilégios** sobre a relação **conceda esses privilégios** a outros usuários.

Proteção Parcial do Banco de Dados

- **Mecanismos de Segurança Discretos**
  - **Exemplo de concessão de privilégios**
    - Administrador cria contas A1, A2, A3 e A4.
    - A1 pode criar tabelas no esquema “universidade”.

GRANT create **ON** universidade.* **TO** A1;

- A1 cria duas tabelas – empregado e departamento.

EMPREGADO

NOME	NUMERODOSEGUROSOCIAL	DATANASC	ENDERECO	SEXO	SALARIO	NRD

DEPARTAMENTO

NUMEROD	NOMED	NUMSEGUROSOCIAL_GER

Proteção Parcial do Banco de Dados

- **Mecanismos de Segurança Discretos**
  - A1 concede para A2 privilégio para incluir e excluir tuplas nas duas tabelas.

GRANT insert, delete **ON** empregado, departamento **TO** A2;

  - A1 concede para A3 privilégio para recuperar informações nas duas tabelas e para propagar o privilégio.

GRANT select **ON** empregado, departamento **TO** A3 **WITH GRANT OPTION**;

Proteção Parcial do Banco de Dados

- **Mecanismos de Segurança Discretos**
  - A3 concede para A4 privilégio para recuperar informações na tabela empregado.

    GRANT select **ON** empregado **TO** A4;

  - A1 revoga o privilégio de recuperação sobre a relação empregado de A3.

    REVOKE select **ON** empregado **FROM** A3;

    - O quê acontece com o privilégio de A4?

Proteção Parcial do Banco de Dados

- **Mecanismos de Segurança Discretos**
  - Novamente, A1 concede para A3 privilégio, porém mais restrito. Recuperar apenas os atributos nome, datanasc e endereco e apenas as tuplas com dno = 5 com propagação.

```
CREATE VIEW A3empregado AS
SELECT nome, datanasc, endereco
FROM empregado
WHERE dno = 5;

GRANT select ON A3empregado TO A3
WITH GRANT OPTION;
```

Proteção Parcial do Banco de Dados

- **Mecanismos de Segurança Discretos**
  - A1 concede para A4 o privilégio de atualizar apenas o atributo salario de empregado.

GRANT update **ON** empregado(salario) **TO** A4;

Proteção Parcial do Banco de Dados

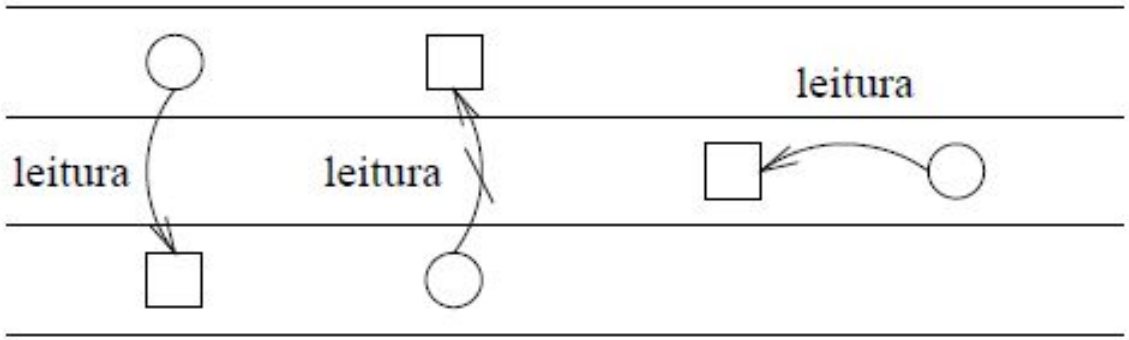
- **Mecanismos de Segurança Obrigatórios**
  - Dados e usuários são classificados considerando **Classes de Segurança**.
  - Abordagem Multinível.
  - **Classes de Segurança Típicas**
    - Altamente Secretas (AS)
    - Secretas (S)
    - Confidenciais (C)
    - Não Confidenciais (NC)
  - **Níveis de Segurança**
    - AS >= S >= C >= NC

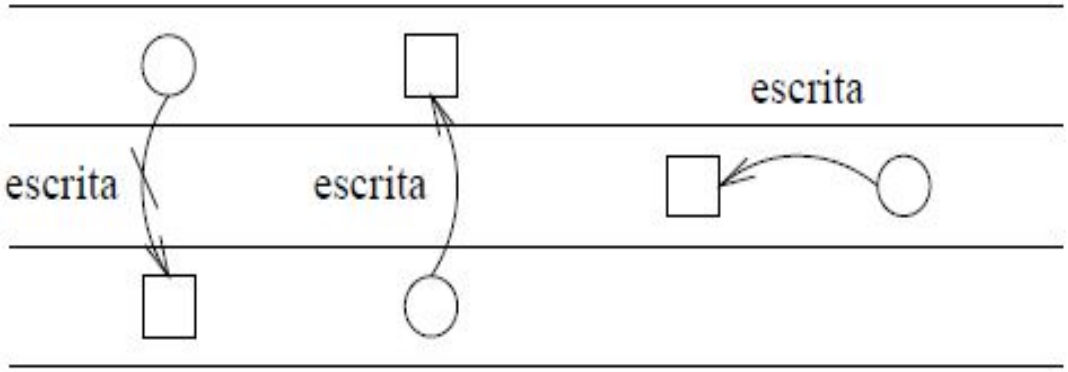
Proteção Parcial do Banco de Dados

- **Mecanismos de Segurança Obrigatórios**
  - **Modelo de segurança Multinível Bell-LaPadula**
    - Sujeito (usuário, conta, programa)
    - Objeto (relação, tupla, coluna, visão, operação)
  - Duas **restrições** são impostas sobre o **acesso de dados** baseando-se nas **classificações sujeito/objeto**.
    - Um sujeito S não tem permissão de **leitura** sobre um objeto O a menos que classe(S) >= classe(O) (**Propriedade de Segurança Simples**).
    - Um sujeito S não tem permissão de **escrita** sobre um objeto O a menos que a classe(O) >= classe(S) (**Propriedade Estrela**).

Modelo de Segurança Bell-Padula

- **Foco**
  - Confidencialidade





Proteção de Bancos de Dados Estatísticos

- **BD Estatísticos**
  - Utilizados para produzir **estatísticas** de **várias populações**.
  - Podem conter **dados confidenciais**, os quais devem ser **protegidos** contra o **acesso de usuários**.
  - **Possuem Controle de Inferência.**
  - Permitem recuperação de diferentes informações, tais como **média**, **soma** e **desvio padrão** de **indivíduos** de uma **população**.

Proteção de Bancos de Dados Estatísticos

- **Exemplo**
  - **Consulta com sexo = “M”**
    - População masculina.
  - **Consulta com sexo = “M”, graduação = “Computação”, cidade = “Maringá” e estado = “PR”**
    - População de homens que cursaram Computação e moram em Maringá.

Proteção de Bancos de Dados Estatísticos

- **Problema**

```
SELECT COUNT(*)
FROM pessoa
WHERE graduação = “Computação”
      AND sexo = “M” AND
         Cidade = “Maringá” AND estado = “PR”;

SELECT AVG(salário)
FROM pessoa
WHERE graduação = “Computação” AND
   sexo = “M” AND Cidade = “Maringá”
                              AND estado = “PR”;
```

Proteção de Bancos de Dados Estatísticos

- **Técnicas que podem ser utilizadas para evitar problemas**
  - Proibição da recuperação de dados individuais
    - **Proibição de consultas** que **recuperam** apenas **valores de atributos** e a **garantia** de que apenas **funções estatísticas** serão invocadas.
  - **Proibição da recuperação de informações** sobre um número pequeno de tuplas, a ser definido.
  - **Proibição de sequências de consultas** que referem-se repetidamente à **mesma população de tuplas**.

Proteção de Dados Sigilosos

- **Exemplos de Serviços de Segurança**
  - Privacidade de conteúdo
    - Cifrar é um meio de manter os dados seguros em um ambiente inseguro.

    - **Uso de Algoritmos de Criptografia**

Criptografia

- **Exemplo de Sistema de Criptografia**
  - **Criptografia de Chave Assimétrica**
    - Algoritmos são baseados em funções matemáticas.
    - Algoritmos envolvem o uso de **duas chaves separadas**
      - Chave Pública
      - Chave Privada

Criptografia

- **Exemplo de Sistema de Criptografia**
  - **Funcionamento**
    - **Entrada do algoritmo**
      - Texto puro.
    - **Processamento Criptografia**
      - Realiza sucessivas transformações no texto puro.
    - **Chaves**
      - Utilizadas para cifrar (**pública**) e decifrar (**privada**).

Criptografia

- **Exemplo de Sistema de Criptografia**
  - **Funcionamento**
    - **Resultado**
      - Mensagem embaralhada. Representa a saída do algoritmo.
    - **Processamento Descriptografia**
      - Recebe o texto cifrado e a chave correspondente. Produz o texto de entrada.

Considerações Finais

- Neste material, os principais assuntos relacionados com a **segurança** foram apresentados.

- **Assuntos**
  - Proteção do Banco de Dados
  - Proteção de Regiões
    - Controle de Acesso Discricionário
    - Controle de Acesso Obrigatório
  - Proteção de Banco de Dados Estatísticos
  - Proteção de Dados com Criptografia

Referências

- Sistemas de Banco de Dados. Elsmari e Navathe. Pearson-Addison Wesley, Sexta Edição.